プラットフォーム脆弱性検査

プラットフォーム脆弱性検査
実施概要

2024年6月
リクルート　セキュリティオペレーションセンター
プロダクトセキュリティアシュアランスG

プラットフォーム脆弱性検査について

※以下、PF脆弱性検査とします

本検査とは

- 検査対象ホストに対して、サーバの OS やミドルウェア、ネットワーク機器の脆弱性の検査を実施します
- リクルート セキュリティ統括室が要対応と判断した内容を連絡します

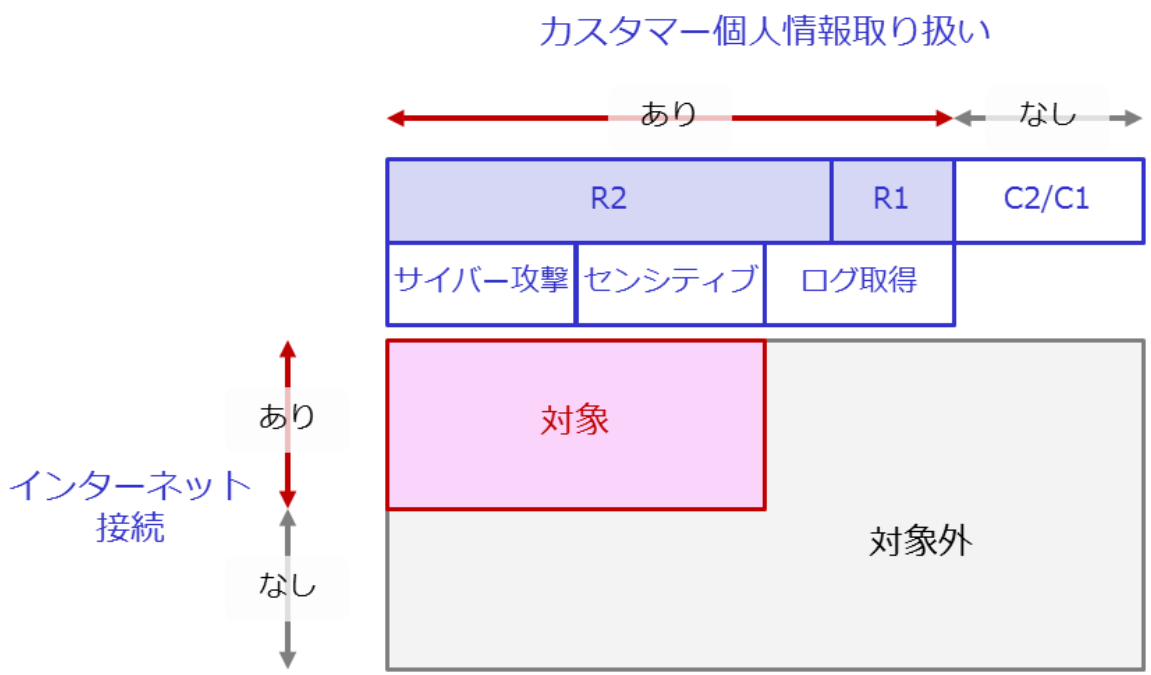
目的

- 事業会社がサービス提供に使用しているプラットフォームに脆弱性がないかを確認し、潜在的なリスクを低減すること

検査対象について

以下の条件をすべて満たすものが検査対象となります

- RisCoより申請された案件
- RisCoでR2/センシティブ対応レベル以上と判定されている
- システムで取り扱うサービスランクR1/R2の情報件数（見込み）を500件以上保持している
- インターネットに公開している



検査の実施について

■実施時期

原則として、C/O後５営業日以内に実施としており、検査日程はシステム担当者と調整します

■検査方法

サーバのOSやミドルウェア、ネットワーク機器に対して

ツールを利用した脆弱性検査を実施します

■体制

リクルート セキュリティオペレーションセンター

プロダクトセキュリティアシュアランスGが担当します

■コスト

検査費用は発生しませんが、以下の項目は事業会社負担となります

・検査に関わる環境設定（非監視依頼など）の費用

・脆弱性改修にかかる費用

検査の流れについて

✓ 検査の案内が届いたら

検査の基本情報をご返送いただき、検査日程の調整をお願いします（次頁②）。
併せて、検査の準備もお進めください（次頁③）　。

✓ 検査の結果、脆弱性が発見されたら

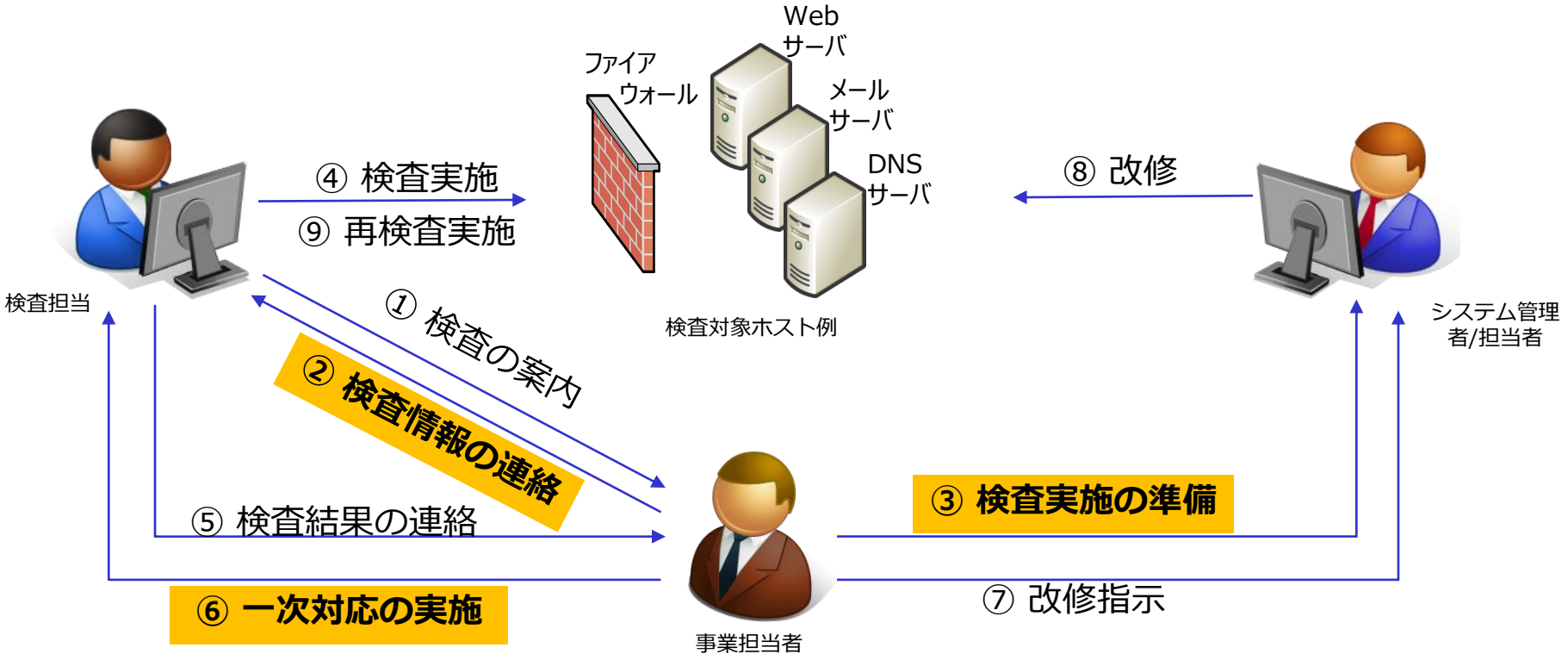
緊急の場合は＜出来るだけ速やかに＞、High、Mediumの場合は＜5営業日以内＞に対策案を立ててご連絡ください（次頁⑥）　。
立案の際、検査結果に対策方針例も示しておりますのでご参考にしてください。
それぞれのリスクレベルに応じて、下表のように改修期限が設定されております。

リスクレベル	対応期限目安
緊急	出来るだけ速やかに
High	1ヶ月以内
Medium	3ヶ月以内
Low	任意

Medium以上の脆弱性は、改修後に再検査を実施し、改修が適切かを確認します。
改修完了時にはご連絡ください。

検査フロー

- PF脆弱性検査は、以下①～⑨の流れで実施します
- 事業担当者/システム担当への依頼事項の発生する箇所をオレンジ色に表記しています
  詳細は次頁にて説明します



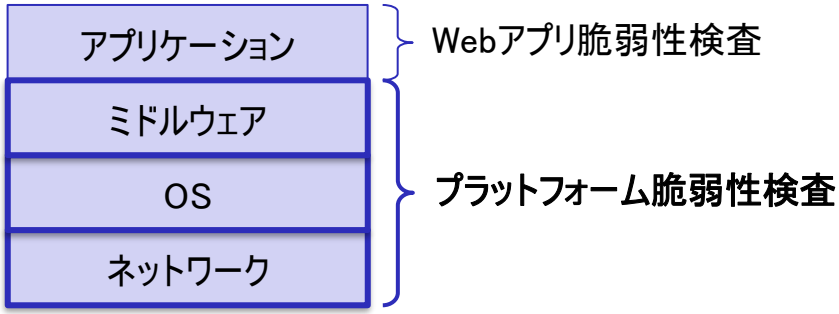
検出された脆弱性のリスクレベルの定義と対応について

検査結果として連絡する脆弱性のリスクレベルは以下の通りです

リスクレベル	定義	対応期限
Critical	インターネットを通じたワームへの感染や、サーバへの侵入、大量の情報漏えい、横断的なサービス停止の原因となりえるもの	出来るだけ速やかに
High	ユーザ情報をはじめとする重要情報の機密性、完全性、可用性、またはシステムリソースの完全性や可用性が侵害されうるもの	1ヶ月以内
Medium	認証の必要性や、特定の環境にのみ影響するなどの環境的な要因で、脆弱性の影響が大幅に軽減されうるもの	3ヶ月以内
Low	環境的な特性によって、脆弱性の影響をほぼ免れることができうるもの	無し
Info	脆弱性ではない情報など	無し

【補足資料１】　プラットフォーム脆弱性検査とは

■ プラットフォーム脆弱性とは

- サーバのOSやミドルウェアに存在する脆弱性の事。
- これが存在していると、「外部からの不正アクセス（攻撃）により、次の様な被害が発生する可能性」がある。
  ① リモートからのシステムの乗っ取り
  ② サービスの停止やシステムの破壊
  ③ 個人情報等、重要な情報の漏洩

- プラットフォーム脆弱性は、次の様なものに起因する。
  - サーバのOSやミドルウェアの不具合
    （いわゆる、セキュリティホールの事）
  - サイト管理部門における対策モレ
    （OSやミドルウェアのパッチを適用していない）
  - サイト管理部門における設定の不備
    （不必要にインターネットに公開しているなど）